

Communications Security Policy

Policy ID: HH-ISMS-06 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

Classification: Internal

1. Purpose

Communications security governs how data moves between systems, between envs, and across the public internet. A hospital system leaks information through the path of least resistance — and that path is usually a misconfigured firewall, a stale TLS cert, or a credential sent over an unencrypted channel.

This policy defines **network architecture**, **TLS posture**, **API authentication**, **data-in-transit protections**, **firewall rules**, and **third-party integration security** for Haritha Hospitals. It is the sibling to 05-operations-security (which covers ops-time decisions) and 04-cryptography (which covers the crypto primitives themselves).

The 2026-08-29 prod DB password drift (LEARNINGS #154) and the unicorn - -preload outage (LEARNINGS #153) both involved communications paths — the SSH channel for the password, and the HTTP channel for the failed requests. A weak communications posture amplifies every other failure.

2. Scope

2.1 In scope

- **Network architecture** — 3-env isolation (pberpprod/pberpqa/pberpdev), DuckDNS public exposure, internal Docker bridge networks, offsite VPS connectivity.
- **TLS / SSL** — Let's Encrypt cert lifecycle for *.duckdns.org subdomains, TLS-only-on-prod, HSTS.
- **API security** — REST API auth (token-based + session-based), rate limiting, CORS.
- **Email security** — SMTP if any (TBD; tracked).
- **Data in transit** — DB connections, backup rsync, SSH, internal Docker traffic.
- **Firewall rules** — DuckDNS exposes only 80/443; container-level isolation via Docker networks; host iptables.
- **Third-party integrations** — biometric, payroll, teleconsultation, offsite rsync target.

2.2 Out of scope

- **SSH key generation, storage, and rotation** — see 04-cryptography §3.4.
- **Backup storage and retention** — see 05-operations-security §3.1 and 08-business-continuity §3.
- **Application-level authentication and authorization** — see 02-access-control.
- **Database credentials** — see 04-cryptography §3.1.
- **Wire-level protocol design** for the custom Frappe app — out of scope (uses framework defaults).

3. Policy Statement

3.1 Network architecture

1. **Three-env isolation.** pberpprod, pberpqa, and pberpdev run as separate Docker Compose stacks on the main VPS. Each has its own Docker network namespace (Compose's

default network per project). **Cross-env traffic is not routed by default** — only shared path is the host's Docker daemon.

2. **DuckDNS public exposure.** The three sites are exposed at pberpPROD.duckdns.org, pberpDEV.duckdns.org, pberpqa.duckdns.org. All three resolve to the same VPS public IP (144.217.163.228); Nginx distinguishes by Host: header.
3. **Internal Docker bridge networks.**
 - Prod: erp-prod_default on 172.27.0.0/16 (per MEMORY.md PROD specifics).
 - Dev/QA: similar bridge ranges, separate per Compose project.
 - **No encryption between containers** — relies on single-tenant network isolation. Acceptable because the network has no other tenants. If a second operator joins, re-evaluate per Edge Case 1.
4. **Offsite connectivity.** Outbound SSH from main VPS (vijay) to venkat@135.125.196.35 uses /root/.openclaw/venkat_vps_key (per-host key separation per 04-cryptography §3.4). Inbound SSH to main VPS uses /root/.openclaw/ssh_key. Reverse direction (venkat → main) uses /home/venkat/.ssh/id_ed25519.
5. **No public IP exposure beyond nginx-proxy.** All other containers (DB, Redis, scheduler, backend) are NOT published to host ports. Only nginx-proxy accepts host-port traffic (80/443).
6. **DNS.** DuckDNS provides dynamic DNS for the VPS's public IP. The duckdns update token lives in the frappeclaw compose env (DUCKDNS_TOKEN). Rotation cadence per 04-cryptography §3.5.

3.2 TLS / SSL

1. **TLS-only on public endpoints.** No HTTP for production data. Nginx serves an HTTP→HTTPS redirect (301) for any accidental plain-HTTP request.
2. **Let's Encrypt via acme-companion.** All three *.duckdns.org subdomains use the nginx-proxy + acme-companion (let's-encrypt-companion) pattern. Cert is auto-renewed at 30 days remaining.
3. **Daily heartbeat probe** (../04-runbooks/04.2-daily-ops.md Step 5) asserts cert expiry > 14 days. If < 14 days → subagent force-renews via docker exec nginx-proxy /app/force-renew. If still failing → SEV-3 alert.
4. **TLS version.** TLS 1.2+ only. TLS 1.0/1.1 disabled at Nginx (ssl_protocols TLSv1.2 TLSv1.3;). Strong ciphers (Mozilla "Intermediate" profile).
5. **HSTS.** Strict-Transport-Security: max-age=63072000; includeSubDomains set on all responses. Submission to the HSTS preload list is tracked in 04-cryptography §3.3 + §9 (future).
6. **No self-signed certs in prod.** Dev/QA may use self-signed for local testing; production cert is always Let's Encrypt. Edge case 2 covers the failure mode.
7. **Internal TLS.** Backend ↔ DB, backend ↔ Redis: **plain TCP** (single-tenant Docker network). Cross-host DB access (e.g., analyst SSH tunnel) uses SSH-tunneled TCP — effectively TLS by virtue of the SSH layer. Direct DB connections from outside the Docker network require an SSH tunnel.

3.3 API security

1. **REST API auth model.**
 - **Session-based** for browser users (Frappe's standard cookie session).
 - **Token-based** for service-to-service or programmatic access (Frappe Authorization: Bearer <token> header). Tokens are scoped per-user; per 02-access-control §3.2.6.
 - **API-key + secret** for any external webhook-style integration (none today; tracked in Edge Case 5).

2. **Rate limiting.** Nginx limit_req zone for /api/ paths (e.g., limit_req_zone \$binary_remote_addr zone=api:10m rate=10r/s;). Specific to login endpoints: stricter limit(limit_req_zone ... rate=1r/s;) to slow brute-force.
3. **CORS.** Frappe's built-in CORS handling; only allow-listed origins may call the API from a browser. Access-Control-Allow-Origin: <allowlisted> is set per env (prod allowlist = TBD; dev/QA = * for local testing).
4. **No http:// for API endpoints.** All API requests must be HTTPS. Mixed-content blocks are enforced by the browser.
5. **Per-endpoint authorization.** Even after auth, RBAC role checks apply per 02-access-control. A valid token does not bypass role checks.

3.4 Email security

1. **No PHI or PII in email body or attachments.** Per 01-info-security §3.5 ("No production data on personal devices") and per DPDP Act 2023.
2. **SMTP is not currently used by Haritha systems.** If a future integration requires sending email (e.g., password reset notifications, payroll slips), use a transactional email provider with TLS-only and SPF/DKIM/DMARC configured. Tracked as future in §9.
3. **TLS-only for SMTP outbound** (when implemented). No opportunistic TLS.
4. **No inbound SMTP** on Haritha infrastructure. Mail server is a separate concern; we don't operate one.

3.5 Data in transit

1. **DB connections (within Docker network):** plain TCP. See §3.1.3 for rationale.
2. **DB connections (cross-host):** SSH tunnel only. No direct MariaDB port exposure.
3. **Backup transfer:** rsync -av over SSH. The SSH key is the offsite key (/root/.openclaw/venkat_vps_k). All bundle + sidecar (*.tar.gz + *.sha256) files are transferred atomically per rsync's incremental algorithm. **Secure by design** — no separate crypto layer needed; SSH provides both encryption and integrity.
4. **Git operations:** SSH only (git@github.com:...). No HTTPS PAT for push (HTTPS PATs are accepted for read-only operations).
5. **Internal monitoring/heartbeat traffic:** SSH from subagent to VPS; HTTP from VPS to subagent for status pings. All authenticated via SSH key.

3.6 Firewall rules

1. **Public ingress:** TCP 80 + TCP 443 only. All other ports are dropped at the host firewall (UFW or iptables — verify in §3a Current State).
2. **Public egress:** TCP 443 (HTTPS) + TCP 80 (HTTP→HTTPS redirect source) + TCP 22 (SSH) outbound. DuckDNS update uses HTTPS outbound.
3. **SSH ingress:** TCP 22, key-only auth (PermitRootLogin no, PasswordAuthentication no). Source IP allowlist is not currently configured (would be a defense-in-depth improvement).
4. **Container-level isolation:** Each Compose project is on its own bridge network. Cross-project traffic must traverse the host (i.e., publish ports or use network_mode: host).
5. **Offsite VPS ingress:** TCP 22 from main VPS IP only. Outbound: TCP 22 to main VPS + TCP 80/443 for updates.

3.7 Third-party integrations

1. **Inventory required.** Every third-party integration gets an inventory entry per 03-asset-management §3.1. Name, data shared, classification, contract, retention, sub-processors.

2. **Classification inheritance.** A vendor storing Haritha PHI inherits Haritha's classification by contract (Confidential). The integration is treated as a Vendor: SaaS row in the inventory.
3. **Authentication.** Per-integration credentials (API key, OAuth token) are stored in `apps/haritha_hospital/.env` (gitignored, mode 0600) per 04-cryptography §3.1.3. Never in fixtures, never in source code.
4. **Webhook security.** Inbound webhooks (none today; future) must use HMAC signature verification. Reject unsigned requests.
5. **Data residency.** Vendors storing PHI must have data centers in India (DPDP Act 2023 + IT Act 2000). Cross-border transfer requires explicit contract clause + Venkat approval.

3a. Current State (as of 2026-08-29)

What we have TODAY

Communications layer	Component	Where it lives	Status
Public DNS	DuckDNS	<code>pberpPROD.duckdns.org</code> , <code>pber-pDEV.duckdns.org</code> , <code>pber-pqa.duckdns.org</code> , <code>dev-erp.duckdns.org</code> , <code>pbapps.duckdns.org</code>	Give, A records pointing to VPS public IP
Public DNS	duckdns update token	<code>frappeclaw compose env</code>	Live, annual rotation cadence
Public ingress	nginx-proxy (80/443)	<code>erp-{env}-* compose + nginx-proxy container</code>	Live
TLS	Let's Encrypt via acme-companion	<code>nginx-proxy companion container</code>	Live, auto-renewed
TLS	Cert probe	<code>daily ops runbook Step 5</code>	Live
TLS	HSTS header	<code>nginx response header</code>	Live (max-age=63072000, no preload yet)
Internal network	Docker bridge (per env)	<code>erp-prod_default</code> on <code>172.27.0.0/16</code>	Live
Internal traffic	Backend ↔ DB	plain TCP on Docker network	Live (single-tenant)
Internal traffic	Backend ↔ Redis	plain TCP on Docker network	Live (single-tenant)
SSH	Main VPS ingress	TCP 22, key-only, <code>PermitRootLogin no</code>	Live
SSH	Offsite VPS ingress	TCP 22 from main VPS IP, key-only	Live
SSH	Host firewall (UFW)	per-host	Verify in next ops review
Backup rsync	main → offsite	SSH key <code>/root/.openclaw/venkat_vps_key</code>	Live

Communications layer	Component	Where it lives	Status
Backup rsync	offsite → main (dev-erp)	SSH key /home/venkat/.ssh/id_ed25519	Live
API auth	Session (browser)	Frappe framework	Live
API auth	Token (programmatic)	Frappe per-user API tokens	Live
API rate limit	Nginx limit_req	nginx-erp.conf	Verify (planned, may not be active today)
CORS	Frappe framework	per-env allowlist	Live (prod allowlist = TBD)
Webhooks	inbound	none today	n/a
SMTP outbound	transactional email provider	none today	Future (§9)
Third-party SaaS	biometric, payroll, teleconsultation	none today	Future (§9)

What is WORKING

- **TLS auto-renewal** has been running smoothly since the initial setup. Daily heartbeat probes cert expiry; no cert incident to date.
- **Docker network isolation** between envs is correct. Each Compose project has its own bridge; containers in one cannot reach containers in another without explicit host-port publishing.
- **SSH key separation** per host (main vs offsite) bounds blast radius (LEARNINGS 2026-05-23 batch).
- **Backup rsync over SSH** is secure by design — no extra crypto layer needed for confidentiality or integrity-in-transit.
- **HSTS header** is set on all responses; submission to the preload list is the only remaining step (tracked).
- **No public IP exposure** beyond nginx-proxy. DB and Redis ports are not bound to host interfaces; only the bridge network can reach them.
- **PermitRootLogin no** on both VPSes. Root can only be reached via sudo from vijay / venkat.

Known GAPS

1. **No UFW / iptables rule inventory.** The host firewall rules are implicit (whatever the VPS provider sets by default + anything added ad-hoc). No explicit deny-all baseline. Tracked in §9.
2. **No source IP allowlist on SSH.** Brute-force protection relies on key-only auth + fail2ban (verify presence). Defense-in-depth would add IP allowlist (AllowUsers vijay@<specific CIDR>). Tracked.
3. **API rate limiting may not be active.** The plan was limit_req on /api/, but the actual nginx config status needs verification. Tracked in §9.
4. **No CORS allowlist for prod.** Default Frappe CORS may be permissive. A prod-specific allowlist is a future improvement.
5. **No HSTS preload.** HSTS header is set, but the domain is not in the browser preload list. A first-visit MITM could downgrade. Tracked in 04-cryptography §3.3 + §9.
6. **No SSL Labs grade check.** Annual external scan (ssllabs.com/sslltest/) is policy (04-cryptography §5) but not yet scheduled.
7. **No formal email integration security review.** No SMTP today, so the gap is hypothetical. Future integrations require DPDP-compliant review.

8. **No vendor security review checklist.** Per 03-asset-management §6a Edge Case 5, a vendor onboarding checklist for PHI-storing SaaS is a future improvement.

These gaps are explicit v1 scope decisions. Listing them is transparency, not apology.

3b. Concrete Examples (Haritha history)

Real communications-security incidents and near-misses that shaped this policy.

Example 1 — 2026-08-29 prod DB password drift over SSH (LEARNINGS #154)

- **What happened.** Production DB login returned 401. Venkat reached for the password in `MEMORY.md` (sent over SSH session) — both stored literals were stale.
- **Root cause.** The “source of truth” was the container env, not the doc. The SSH session itself was secure (key-only auth, encrypted channel); the leak was in the documentation practice (hardcoded literals that drift).
- **Response.** Canonical read pattern: `docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD`. Quarterly verification per 04-cryptography §5.
- **Communications-security lesson.** A secure channel does not protect against operator-side errors. The communications posture was correct; the secret-state management was wrong. §3.5.3 (backup transfer over SSH) and §3.1.6 (container env as source of truth) work together — never write a secret into a long-lived doc that traverses a communications channel you don’t control.

Example 2 — 2026-08-29 gunicorn outage, HTTP-side (LEARNINGS #153)

- **What happened.** After `bench install-app haritha_hospital`, every HTTP request returned `ModuleNotFoundError` → HTTP 500. The HTTPS channel was fine; the application layer (gunicorn → backend Python) was broken.
- **Root cause.** Gunicorn `--preload` froze `sys.path`; new apps invisible until container restart.
- **Response.** `docker restart erp-{env}-backend-1` in parallel.
- **Communications-security lesson.** “TLS works” ≠ “service works”. The cert was valid, the TLS handshake was correct, the application layer failed. This is why §3.2.5 requires post-deploy verification that exercises the *running* process, not just the cert. The HTTP-side lesson is that the response status code (5xx) was the signal — the heartbeat should also probe a known-good app endpoint, not just the cert.

Example 3 — 2026-08-22 SSH key chmod issue (LEARNINGS #93)

- **What happened.** `/root/.openclaw/*.key` files occasionally lost `0600` mode. SSH refused to use them.
- **Root cause.** Filesystem mode is host-level state that drifts.
- **Response.** Periodic `chmod 0600` in bootstrap script.
- **Communications-security lesson.** A private key with `0644` is effectively public. The SSH *protocol* enforces key auth, but if the key file is readable by anyone on the host, the protocol’s protections are moot. §3.6.3 codifies key-mode discipline as a communications-security primitive.

Example 4 — 2026-05-23 SSH key compromise + backup key separation (LEARNINGS 2026-05-23 batch)

- **What happened (hypothetical drill).** Venkat’s laptop compromised. Primary SSH key for the main VPS was on it.

- **Root cause.** Single-machine single-key infrastructure would have collapsed entirely.
- **Response.** Key-separation model: main VPS key on Venkat's machine; offsite key on a different machine. Compromise of one does not equal compromise of the other.
- **Communications-security lesson.** Key distribution is a security boundary, not just algorithm choice. A 4096-bit RSA key on a single compromised host is 100% compromised. §3.1.4 + §3.6.3 codify per-host key separation.

Example 5 — 2026-08-14 sub-agent heredoc + secret-leak near-miss (LEARNINGS 2026-08-14 batch)

- **What happened.** A subagent's bash heredoc inside docker exec had unescaped back-ticks. The heredoc body was evaluated by the outer shell before being written to file. A literal `${MYSQL_ROOT_PASSWORD}` reference was expanded by the local env (which had a different value) and committed to the script.
- **Root cause.** Heredoc with unquoted delimiter (EOF) allows shell expansion inside the body.
- **Response.** Heredoc discipline: always 'EOF' (single-quoted) for any body that may contain secrets.
- **Communications-security lesson.** Secrets can leak through shell expansion even when no human shares them. §3.5 mandates “never let a secret traverse a shell expansion boundary” — single-quoted heredocs, env vars passed via docker exec -e.

Example 6 — 2026-08-18 cron race condition + SSH-driven config drift (LEARNINGS #77, #78)

- **What happened.** Three concurrent agents edited the crontab via `crontab -l | sed | crontab -`. Last-writer-wins. The backup cron state diverged from intent across SSH sessions.
- **Root cause.** Read-modify-write pattern with no transactional isolation.
- **Response.** Atomic pattern: heredoc → tempfile → crontab <file>. Documented in LEARNINGS #77 and applied here.
- **Communications-security lesson.** Config mutations need the same care as DB writes — even when the channel (SSH) is secure. Shared system state across SSH sessions is still shared state. §3.6 + the cross-link to 05-operations-security §3.2.4 codify atomic edits.

Example 7 — 2026-08-15 git commit identity drift (LEARNINGS MEMORY rule #11)

- **What happened.** Agents committed under varied identities (erpclaw, claude, venkat-narasimha). The SSH-push channel was secure; the audit trail was broken.
- **Root cause.** No enforced git identity on container + VPS.
- **Response.** git config --global user.name venkat-narasimha && user.email srivenkatnarasimha@gmail.com on every bootstrap. MEMORY rule #11 (now non-negotiable).
- **Communications-security lesson.** A secure channel preserves bytes, not identity. If commits are under different identities, you cannot prove who signed which change. Combined with §3.5.4 (SSH-only git push), identity consistency is required to attribute a secret-commit to a person.

Example 8 — 2026-08-05 cron timezone + restart (LEARNINGS 2026-05-28 batch)

- **What happened.** VPS timezone was changed; cron daemon continued using the OLD timezone for schedule evaluation. Jobs didn't run for ~6h until cron was restarted.

- **Root cause.** cron reads /etc/localtime + /etc/timezone only at start. Timezone changes don't auto-propagate to running cron.
- **Response.** Standard post-timezone-change checklist: systemctl restart cron (or docker restart if cron is in a container). Daily heartbeat verifies slot ran within ± 15 min.
- **Communications-security lesson.** Time is a security primitive. Slot timing drift could mask a backup failure or a delayed TLS renewal. §3.2.3 + §3a "What is WORKING" call out the heartbeat probe for cert expiry + slot freshness.

4. Responsibilities

Role	Responsibilities
Venkat Narasimha (Owner)	Approves this policy + exceptions. Approves any third-party integration storing PHI. Owns the duckdns update token. Performs annual TLS grade check.
Processbricks admin	Maintains nginx config + cert renewal automation. Verifies TLS daily. Verifies SSH key mode (0600). Audits API token rotation annually. Reviews firewall rules quarterly.
Subagents (automation)	Heartbeat probe cert expiry + container health + offsite rsync freshness. Surface TLS renewal failures within 1h. Never auto-reconfigure firewall without Venkat approval.
Users	Never paste a credential into Slack/email. Never commit a secret to git. Use SSH keys for all VPS access.
Vendors	Bound by contract to TLS-only + DPDP-compliant data residency. Notify of any CVE within 7 days.

5. Compliance Measurement

Check	Frequency	Owner	Source of truth
TLS cert expiry > 14 days	Daily	admin	openssl + heartbeat
TLS grade $\geq$ A (ssllabs)	Annually	admin	external scan
HSTS preload submission	Once + on domain change	Venkat	hstspreload.org
SSH key mode = 0600	Weekly	admin	stat
SSH key age $\leq$ 365 days	Annually	Venkat	key creation date
API token age $\leq$ 365 days	Annually	admin	tabAPI Token table
CORS allowlist review	Quarterly	admin	nginx config + Frappe settings

Check	Frequency	Owner	Source of truth
Rate limit policy review	Quarterly	admin	nginx config
Host firewall rules audit	Quarterly	admin	ufw status / iptables -L
Vendor inventory review	Per new integration	Venkat	asset-inventory.md
Curl smoke for each env	Daily	admin	daily ops runbook
Cross-host SSH tunnel test	Weekly	admin	dev/QA/prod DB connectivity
DuckDNS token age ≤ 365 days	Annually	Venkat	token issuance date

KPI target: zero cert incidents per year; zero unauthorized SSH sessions; zero plaintext credentials in transit; zero cross-env network paths; all vendor integrations in inventory with classification.

6. Exceptions

1. **Internal Docker network traffic is plain TCP** (§3.1.3, §3.5.1). Tracked as a known exception — acceptable because the network is single-tenant. Revisit if a second operator joins or if the trust boundary expands (e.g., adding a SaaS that talks to the DB).
2. **No source IP allowlist on SSH** (§3a GAPS #2). Acceptable risk for v1 (key-only auth is the primary control). Tracked as future improvement.
3. **No HSTS preload** (§3a GAPS #5). HSTS header is set with max-age=63072000; includeSubDomains but submission to the preload list is pending.
4. **No UFW / iptables baseline inventory** (§3a GAPS #1). Implicit default + ad-hoc additions. Formal inventory + explicit deny-all baseline is a future improvement.
5. **No production CORS allowlist** (§3a GAPS #4). Default Frappe CORS may be permissive. Future: define a per-env allowlist.
6. **No inbound SMTP** (§3.4.4). Mail is not a service we operate; outbound SMTP is TBD.
7. **No third-party SaaS today** (§3.7.5). When added, contract review + classification inheritance + inventory entry + DPDP-compliant residency are required.
8. **All other exceptions** follow 01-info-security §6.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the policy's boundaries. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — A second operator joins and needs to access the prod network

- **Trigger.** Processbricks hires a second operator who needs read access to prod DB for incident response.
- **Decision matrix.**

Action	Allowed?	Why
Add their SSH key to <code>vi-jay@...:/home/vijay/.ssh/authorized_keys</code>	YES (per 02-access-control §3.4.1)	Standard provisioning; per-host key separation

Action	Allowed?	Why
Provision tabUser on prod with System Manager role	CONDITIONAL	Per 02-access-control §3.3.1; time-boxed + audited
Add their IP to a UFW allowlist	YES (future; not active today)	Defense-in-depth; primary control is still SSH key
Grant them a haritha_ro MariaDB user for analyst queries	YES	Separate from admin; read-only
Re-evaluate “no internal TLS” exception	YES	Two operators = expanded trust boundary; revisit §3.1.3

- **Default action.** Provision per 02-access-control §3.4 Lifecycle. The §3.1.3 plain-TCP-internal exception is explicitly noted in the §6 Exception #1 as conditional on single-tenant. Adding a second operator flips the condition → exception must be formally waived or internal TLS implemented.

Edge case 2 — TLS cert renewal fails (e.g., duckdns is down, ACME challenge blocked)

- **Trigger.** Certbot cannot reach the HTTP-01 challenge endpoint. Cert expires in 5 days.
- **Decision matrix.**

Action	Allowed?	Why
Wait until 3 days remaining; force-renew with certbot renew --force-renewal	YES	Standard renewal force
Switch to DNS-01 challenge (manual TXT record)	YES (if HTTP-01 is blocked)	Certbot supports both
Generate a self-signed cert as emergency fallback	NO	Browsers reject; not a real fallback
Disable TLS temporarily	NO	§3.2.1 — no HTTP for production

- **Default action.** Same as 04-cryptography §6a Edge Case 2. Investigate root cause at 14 days remaining (heartbeat alert). Force-renew at 7 days. Switch challenge type if HTTP-01 is blocked. Roll back the certbot config if the new config is the problem.

Edge case 3 — A vendor requires an embedded API key in the request header (not env-var hookable)

- **Trigger.** A SaaS vendor’s integration spec says the API key must be in the request header; they don’t support OAuth or env-var hooks.
- **Decision matrix.**

Action	Allowed?	Why
Embed the key in haritha_hospital/.env (gitignored, mode 0600)	YES	Per 04-cryptography §3.1.3 + §3.7 of this policy
Embed the key in source code	NO	§3.7.3 — secrets in git

Action	Allowed?	Why
Embed the key in a custom field on a DocType	NO	DB-resident secrets are discoverable via tabVersion
Refuse the integration	YES (if no acceptable placement)	Some integrations are not worth the risk
Add the vendor to asset-inventory.md regardless	YES	§3.7.1 — every integration gets an inventory entry

- **Default action.** .env file, mode 0600, gitignored, rotation cadence per 04-cryptography §3.5. Inventory entry per §3.7.1. Vendor classification inheritance per §3.7.2.

Edge case 4 — A new container is added to the fleet and needs to expose a port

- **Trigger.** A future metrics container (Prometheus) needs port 9090 published to be scraped by Grafana on another host.
- **Decision matrix.**

Action	Allowed?	Why
Publish 9090 in the Compose YAML	NO	§3.6.1 — only nginx-proxy may have host-port bindings
Expose 9090 on the Docker network only (not published)	YES (preferred)	Grafana can reach it via the bridge; no host exposure
Add a UFW rule allowing 9090 from a specific Grafana IP	CONDITIONAL	Acceptable if the IP is stable + Grafana is the only consumer; document in inventory
Use SSH tunnel to reach 9090	YES (for ad-hoc)	No host exposure; one-off access

- **Default action.** Expose on Docker network only. If Grafana is on a different host, route through an SSH tunnel or a second nginx-proxy with auth. Host-port publication requires explicit Venkat approval and a UFW exception logged in the firewall audit.

Edge case 5 — An external webhook integration is added (e.g., payment gateway callback)

- **Trigger.** A future payment gateway sends a webhook to <https://pberpPROD.duckdns.org/api/webhook>
- **Decision matrix.**

Action	Allowed?	Why
Add an Nginx path that accepts the webhook	YES	Standard ingress
Implement HMAC signature verification on the webhook body	YES (mandatory)	§3.7.4 — reject unsigned requests
Add the gateway's IP to a UFW allowlist for /api/webhook/payment	CONDITIONAL	Defense-in-depth; not a substitute for HMAC verification
Use a shared secret in a custom DocType field	NO	DB-resident secrets are discoverable

Action	Allowed?	Why
Use an env-var shared secret in haritha_hospital/.env	YES	Per 04-cryptography §3.1.3

- **Default action.** HMAC signature verification is mandatory. Shared secret in .env. Vendor inventory entry per §3.7.1. Rotation cadence per vendor contract.

Edge case 6 — A user reports slow page loads; is it network, app, or DB?

- **Trigger.** Nurses report Roster page takes 8-10 seconds to load.
- **Decision matrix.**

Step	Probe
1. Is TLS slow?	openssl s_client -connect pberpPROD.duckdns.org:443 + timing
2. Is Nginx slow?	docker logs --since 5m nginx-proxy for latency markers
3. Is backend slow?	docker exec erp-prod-backend-1 bash -c 'supervisorctl status' + worker counts
4. Is DB slow?	docker exec erp-prod-db-1 mariadb ... -e "SELECT id, time, state, info FROM information_schema.processlist WHERE time > 5 ORDER BY time DESC;"
5. Is scheduler slow?	sites/pberpprod.duckdns.org/logs/scheduler.log per LEARNINGS #88

- **Default action.** Step-by-step isolation. If 1 is slow → cert or TLS config issue (rare). If 2 → nginx config issue. If 3 → gunicorn / Python app issue (LEARNINGS #153 class — restart). If 4 → DB query or schema issue. If 5 → scheduler event queue. Network is rarely the root cause; it's almost always the slowest visible layer in the stack so users blame it first.

Edge case 7 — A backup rsync fails with “Permission denied” over SSH

- **Trigger.** Cron-driven offsite rsync fails with Permission denied (publickey). Local backup succeeded; offsite didn't.
- **Decision matrix.**

Action	Why
ls -la /root/.openclaw/venkat_vps_key — verify mode 0600	LEARNINGS #93 — mode drift is the classic cause
ssh -i /root/.openclaw/venkat_vps_key venkat@135.125.196.35 'echo OK' — verify key works	Isolates whether the key file is bad or the remote authorized_keys is bad
ls -la /home/venkat/.ssh/authorized_keys (on offsite) — verify pubkey still present	LEARNINGS #93 — pubkey could be missing after offsite VPS maintenance
Re-add pubkey to offsite authorized_keys if missing	Standard recovery
Verify SSH key still in use per 04-cryptography §3.4	Annual rotation may have removed the old key

- **Default action.** LEARNINGS #93 pattern — fix mode first, then test isolated SSH, then check pubkey. Never chmod 0644 the private key (it's effectively public). Never ssh-copy-id over an insecure channel.

Edge case 8 — DuckDNS returns the wrong IP for a subdomain

- **Trigger.** dig pberpPROD.duckdns.org returns an old VPS IP after a provider migration.
- **Decision matrix.**

Action	Allowed?	Why
Manually call <code>https://www.duckdns.org/update?domains=pberpPROD&token=...&ip=<new_ip></code>	YES	Standard duckdns update
Wait for the cron to update it (5-min interval)	YES (if not urgent)	duckdns-updater service runs in compose
Edit the duckdns IP via the duckdns web UI	YES (manual override)	Web UI is the source of truth
Bypass duckdns and edit the local hosts file	NO	Affects only the local machine; doesn't help real users

- **Default action.** Manual duckdns API call, then verify with dig. If duckdns service is the failure, restart the duckdns-updater container or rotate the token (per 04-cryptography §3.5).

7. Related Documents

- 01-info-security.md — Umbrella + emergency-access + exception flow.
- 02-access-control.md — SSH key distribution + RBAC roles drive what each operator can do.
- 03-asset-management.md — Asset inventory + classification inheritance for vendors.
- 04-cryptography.md — TLS primitives + SSH key management + secret storage.
- 05-operations-security.md — Daily heartbeat + change management (sibling policy).
- 07-incident-management.md — SEV ladder + escalation when a communications failure becomes an outage.
- 08-business-continuity.md — DR + RTO/RPO when communications fail (sibling policy).
- ../04-runbooks/04.2-daily-ops.md — Daily TLS probe + container health.
- ../04-runbooks/04.4-incident-response.md — Triage flow when an outage is suspected.
- ../../../learnings/LEARNINGS.md — Lessons #72 (parent-verify), #77 (atomic cron), #78 (concurrent cron), #87 (scheduler 1045), #93 (SSH key chmod), #113 (silent exit), #114 (silent cron), #153 (unicorn restart), #154 (DB password drift).
- ../../../MEMORY.md — Tech stack, container names, DB names, VPS IPs, SSH key paths.

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ❑ **Inventory current host firewall rules** on both VPSes (`ufw status verbose` on main, equivalent on offsite). Document baseline + any ad-hoc exceptions. Owner: PA. Target: 2026-09-05. Status: Not Started.
- ❑ **Verify nginx limit_req is active** for `/api/` paths in `nginx-erp.conf`. If not, add it. Owner: PA. Target: 2026-09-05. Status: Not Started.
- ❑ **Verify fail2ban is running** on both VPSes. Owner: PA. Target: 2026-09-05. Status: Not Started.
- ❑ **Run ssllabs.com/ssltest/** on `pberpPROD.duckdns.org` for a baseline grade. Owner: VN. Target: 2026-09-12. Status: Not Started.

Short-term (2026-Q3)

- ❑ **Submit HSTS preload** for `*.duckdns.org` (cross-link 04-cryptography §3.3 + §9). Owner: VN. Target: 2026-10-15. Status: Not Started.
- ❑ **Define prod CORS allowlist** (specific origins; not `*`). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ❑ **Add SSH source-IP allowlist** for main VPS (`AllowUsers vijay@<specific CIDR>`). Defense-in-depth. Owner: VN. Target: 2026-09-30. Status: Not Started.
- ❑ **Author vendor onboarding security checklist** for any PHI-storing SaaS (per 03-asset-management §6a Edge Case 5). Owner: VN. Target: 2026-10-15. Status: Not Started.
- ❑ **Add curl smoke for known-good app endpoints** (not just `/`) to the daily heartbeat — catches the “TLS works but app is broken” failure mode (LEARNINGS #153). Owner: PA. Target: 2026-09-30. Status: Not Started.

Medium-term (2026-Q4)

- ❑ **Annual TLS grade check** (external scan, target $\geq$ A). Owner: PA. Target: 2026-11-15. Status: Not Started.
- ❑ **Define SMTP integration pattern** (TLS-only, SPF/DKIM/DMARC, transactional provider) — when email becomes a requirement. Owner: VN. Target: 2026-12-15. Status: Not Started (no current requirement).
- ❑ **Implement internal TLS for prod DB** (cross-link 04-cryptography §3.6) — when the §3.1.3 single-tenant exception flips. Owner: VN. Target: TBD (depends on second operator onboarding). Status: Not Started.
- ❑ **Quarterly host firewall rules audit** — make it a recurring runbook item. Owner: PA. Target: 2026-10-31. Status: Not Started.
- ❑ **Annual duckdns token rotation** (per 04-cryptography §3.5). Owner: VN. Target: 2026-11-15. Status: Not Started.

Long-term (2027+)

- ❑ **Web Application Firewall (WAF)** in front of nginx-proxy (e.g., ModSecurity + OWASP CRS). Owner: VN. Target: TBD. Status: Not Started.
- ❑ **DDoS protection** at the edge (Cloudflare proxy or similar). Owner: VN. Target: TBD. Status: Not Started.
- ❑ **VPN for admin access** (WireGuard) — replaces direct SSH for some operators. Owner: VN. Target: TBD. Status: Not Started.
- ❑ **mTLS for service-to-service** (when 3+ services need to authenticate). Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- ☐ **Daily TLS cert expiry probe** (../04-runbooks/04.2-daily-ops.md Step 5). Owner: PA. Frequency: daily. Status: Done.
- ☐ **Daily container health probe** (Step 4 of daily ops). Owner: PA. Frequency: daily. Status: Done.
- ☐ **Weekly SSH key mode check** (`stat -c '%a' /root/.openclaw/*.key`). Owner: PA. Frequency: weekly. Status: Not Started.
- ☐ **Weekly cross-host SSH tunnel test** (verify DB reachable via tunnel from at least one env). Owner: PA. Frequency: weekly. Status: Not Started.
- ☐ **Quarterly host firewall rules audit**. Owner: PA. Frequency: quarterly. Status: Not Started.
- ☐ **Annual SSH key rotation** (per 04-cryptography §3.4). Owner: VN. Frequency: annually. Status: Done.
- ☐ **Annual API token rotation**. Owner: VN. Frequency: annually. Status: Done.
- ☐ **Annual duckdns token rotation**. Owner: VN. Frequency: annually. Status: Done.
- ☐ **Annual TLS grade check** (ssllabs). Owner: PA. Frequency: annually. Status: Not Started.
- ☐ **Annual policy review** (re-read, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).

Secure by default. SSH + TLS + least-privilege. Vendor inherits our classification by contract.